Trust Center: Surface Design Directions

These wireframes capture the proposed structure of three Trust Center surfaces: the **landing page** (what users and stakeholders see inside the product), the **workload detail surface** (per-workload attestation drill-down where Builders debug failures and Watchdogs inspect the layered chain of trust), and the **exportable artifacts** (the per-workload Manifest, Result/Governance Record, and Evidence handed to data owners, legal, and buy committees). All are markdown representations — layout intent, not production UI.

> **Updates 2026-05-10:** Workload detail surface section added; status chips, failure types, and exportable-artifact framing updated based on the CLI proof-of-attestation review with Hernan and Katy on 2026-04-29 and reconciled against the Trust Center Product Definition PRD.

> The Trust Center landing page wireframe is based on Q1 research findings (Trust Center + Policy Enforcement experiment, n=7). The exportable artifact wireframe is the primary test instrument for the Q2 buy trigger hypothesis. Both should be treated as strong design directions, not confirmed product decisions.

Trust Center landing page

Structure follows the hierarchy Q1 research surfaced: **policy enforcement summary** → **workload inventory** → **exportable artifact** → **hardware detail**. Participants who saw raw attestation data without policy context first were lost. Hardware detail is present but collapsed by default.

Overview tab

```
TRUST CENTER

  Overview  |  Audit Log
  ──────────────────────────────────────────────────────────
```

```
────────────────
  [ Last 7 days ▾ ]  [ All workspaces ▾ ]

  POLICY ENFORCEMENT
  ┌──────────────────┬──────────────────┬──────────────────┬────
──────────────┐
  │  Active          │  Policies        │  Enforced L30d   │  Bl
ocks L30d    │
  │  workloads       │  enforced        │                  │
│
  │  12              │  47              │  100%            │  8
│
  └──────────────────┴──────────────────┴──────────────────┴────
──────────────┘

  STATE A — Blocked executions tab (default)
  [ Blocked executions ]   Active policies
  [ Search blocked events 🔍 ]
  ──────────────────────────────────────────────────────────────
──────────────────────────────
  Timestamp           Policy              Workload
Pod               Event
  ──────────────────────────────────────────────────────────────
──────────────────────────────
  18 Mar, 2:31 PM     Network policy      Employee HR Assist
hr-assist-7x4k3   Outbound to api.openai.com:443 blocked — no
t in approved allowlist
  18 Mar, 2:14 PM     Runtime integrity   Employee HR Assist
hr-assist-7x4k4   Attestation failed — container image digest
mismatch, workload denied
  18 Mar, 2:11 PM     Network policy      Financial RAG
fin-rag-7x4k5     Inbound aTLS handshake rejected — claims-an
alytics-svc cert not present
  18 Mar, 1:31 PM     Runtime integrity   HR Rag
hr-rag-7x4k6      Attestation failed — LLM_API_ENDPOINT env v
ar did not present valid attestation
```

```
  18 Mar, 12:46 PM    Network policy      Financial RAG
hr-assist-7x4k7   Outbound aTLS failed — payroll-data-api att
estation evidence invalid
  18 Mar, 12:31 PM    Pod access          Employee HR Assist
hr-assist-7x4k8   Pod exec denied — alice.chen@opaque.co atte
mpted kubectl exec on hr-assist-7x4k8
  18 Mar, 11:24 AM    Network policy      Employee HR Assist
hr-assist-7x4k9   Outbound to hr-reporting-vendor.com:443 blo
cked — destination not verified
  18 Mar, 9:39 AM     Runtime integrity   Employee HR Assist
hr-assist-7x4k10  Attestation failed — unexpected volume moun
t /tmp/pii-buffer not in approved deployment
  ──────────────────────────────────────────────────────────────
──────────────────────────────

  STATE B — Active policies tab
  Blocked executions   [ Active policies ]
  [ Search policies 🔍 ]
  ──────────────────────────────────────────────────────────────
──────────────────────────────
  Policy                        Type                Status
Workloads
  ──────────────────────────────────────────────────────────────
──────────────────────────────
  No network egress             Network             ● Active
12 / 12
  TEE required                  Runtime integrity   ● Active
12 / 12
  Shell/exec denial             Pod access          ● Active
8 / 12
  RBAC session scoping          Access              ● Active
12 / 12

  WORKLOAD ATTESTATION
  [ All statuses ▾ ]
```

```
  Workload                Type        Active Inst.     Last att
ested     Mode        Status           Failure type
  ──────────────────────────────────────────────────────────────
──────────────────────────────────────────────────────────────
  ▾ Employee HR Assist  Container   3 pods
Production  [1 FAILED]
    └─ hr-assist-7x4k2              –                24 Jan,
3:41 PM                [VERIFIED]
[Export]
    └─ hr-assist-9m2p1              –                24 Jan,
3:41 PM                [FAILED]         Measurement mismatch
[Export]
    └─ hr-assist-3j8w5              –                24 Jan,
3:41 PM                [VERIFIED]
[Export]
  ▸ HR RAG v2           Workflow    1 pod            24 Jan,
3:41 PM   Dev mode    [ALL VERIFIED]
[Export]
  ▸ Financial RAG v2    Container   2 pods
Production  [ALL VERIFIED]                          [Export]
  ▸ Financial RAG v3    Container   No active inst.
Production  [ALL VERIFIED]                          [Export]

  ──────────────────────────────────────────────────────────────
──────────────
```

Design notes — Overview tab

- Policy Enforcement leads, not attestation. The 4-stat summary gives buyers both the configuration signal (active workloads, policies enforced) and the proof-of-enforcement signal (enforcement rate, blocks count) over the last 30 days before any drill-down.
- **Date range and workspace filters** sit directly under the tab row and apply across both Blocked executions and Active policies sub-views. Defaults: `Last 7 days` × `All workspaces`. Workspace filter is role-scoped — Members see only assigned workspaces; Global Admins and Owners see all.

- The Policy Enforcement section has two sub-tab views: **Blocked executions** (default) and **Active policies**. Blocked executions leads because it is active evidence — proof that enforcement is live — rather than a configuration list. The blocked executions table was well-received in user research — it turns a passive claim into active receipts.
- **Policy enforcement covers three dimensions**, represented as the Policy-column values in both sub-tabs: **Runtime Integrity** (workload configuration match), **Network Policy** (aTLS peer verification and egress enforcement), and **Pod Access Policy** (shell and log access denials enforced by KATA inside the TEE). Each gets a distinct entry in Active policies and a distinct `Policy` column value in Blocked executions.
- **Workload attestation** is a flat, sortable table. Columns: **Workload · Type · Active Instances · Last attested · Mode · Status · Failure type**. Workloads expand to per-pod rows. The per-pod `Export` action triggers the Governance Record for that pod — export is not a single org-wide CTA.
- **Mode column** distinguishes `Production` from `Dev mode` at the workload level. Dev-mode workloads cannot produce a TRUSTED verdict, carry DEV_UNSAFE state, and must be excluded from compliance exports. The Mode column is the primary visual separator; dev-mode rows must also carry the persistent `[DEV MODE — NOT TRUSTED]` indicator in detail views and are ineligible for Governance Record export.
- **Status chips** are the primary attestation signal. Pod-level: `VERIFIED` (pass), `FAILED` (attestation failed), `AT RISK` (attestation hasn't failed outright but state is suspicious — e.g. pod running 10+ min with no verdict, verdict gone stale; surfaced during the CLI demo on 2026-04-29 as a real state the UI needs to represent), `PENDING` (pod recently started, attestation not yet performed; expected during the first 2–3 minutes of pod life). Workload-level: `ALL VERIFIED` (every pod passed), or a count breakdown when any non-passing pod is present (e.g. `12 VERIFIED · 1 AT RISK · 1 FAILED`). Per PRD architectural assumption #1, workload-level status is never a single boolean — attestation cannot be rolled up without hiding failures. Chips must pair color with a glyph or text label — not color-coded alone — to remain parseable for colorblind users.

- **Pod-level drill-down.** Pod rows in the expanded workload tree are clickable and route to the **workload detail surface** described below. The CLI flow walks Builders from workload-status rollup → list of pods → specific pod with progressive verbosity (`-v` per-layer outcome, `-vv` per-measurement detail); the workload detail surface is the UI analogue.
- **Failure type column** distinguishes failure categories on failed rows: *infrastructure failure* (OAS unavailable), *measurement mismatch* (runtime ≠ registered manifest), *invalid evidence* (EAT signature verification failure, freshness failure), *connection rejection* (network policy peer denial). Column is empty on passing rows. *Reconciliation note:* PRD FR-4 treats policy violation (incl. connection rejection) as a subset of *invalid evidence* and lists three top-level categories. The four-category UI split surfaces the user's concern more distinctly — confirm with Hernan whether to flatten to three or retain four (see Open Questions).
- **Search and filter:** each sub-tab has its own search (`Search blocked events` or `Search policies`); a status filter sits above the Workload attestation table.
- **Hardware-level detail is not surfaced on the landing page.** It lives inside the per-workload Governance Record, accessible via Export. This matches the Q1 research finding that participants who saw raw attestation data before policy context were lost.

Audit Log tab

```
TRUST CENTER
[ All workspaces ▾ ]

  Overview  |  Audit Log
  ____________________________________________________________
_____________

  [ Last 30 days ▾ ]  [ Category: All ▾ ]  [ Actor: All ▾ ]
[ Export ]

  Timestamp             Actor                 Action
```

```
Target
  ──────────────────────────────────────────────────────────────────────────────────────────────────
  2026-04-09 14:32      trish@opaque.co      Deployed workflo
w       Finance / KYC Workflow
  2026-04-09 14:30      trish@opaque.co      Updated policy
Finance workspace
  2026-04-09 11:15      system               Attestation comp
leted   pod-a8f2
  2026-04-09 09:44      admin@corp.com       Added member (Us
er)     HR Internal workspace
  2026-04-08 17:01      trish@opaque.co      Registered conta
iner    kyc-workflow:2.4.1
  ...
```

Design notes — Audit Log tab

- The Audit Log answers a different question from attestation: not "did the right thing run?" but "what did it do?" Both tabs live inside Trust Center because both serve the compliance and proof use case.
- Filter by category, actor, target entity, and timestamp. Export is a primary CTA — audit log exports are themselves auditable.
- Access control: Global Admins and Owners see all org-wide events. Members see only their workspace-scoped events.
- At workload level (drill-in from the Workload Attestation list), both an Attestation view and an Audit view should be accessible — scoped to that workload.
- An org-wide Audit Log view — unscoped to any workload — is needed for the compliance officer and security engineer use cases.

Workload detail surface

Per-workload drill-down view, accessible by clicking any pod row in the Workload Attestation table on the landing page. This is the surface where Builders debug attestation failures, where Watchdogs inspect the layered chain of trust, and

where the three exportable artifacts (Manifest, Result, Evidence) are surfaced. Added in this revision based on the CLI proof-of-attestation review (Hernan + Katy, 2026-04-29) and PRD FR-1, FR-3, FR-4.

Pod detail view

```
WORKLOAD: Employee HR Assist
[ ← Back to Trust Center ]                    [ Export Manife
st ]
                                              [ Export Result
]
                                              [ Export Eviden
ce ]   (failure only)

Coverage:  2026-04-09 14:30:02 UTC   (single attestation mome
nt)
Workload:  Employee HR Assist  ·  HR Internal  ·  Production
Pod:       pod-a8f2  ·  Azure (AMD SEV-SNP)  ·  US East

VERDICT
┌──────────────────────────────────────────────────────────────
──────┐
│  ✗  FAILED — Measurement mismatch at Layer 2 (Platform / Po
dVM)  │
└──────────────────────────────────────────────────────────────
──────┘

LAYERED TRUST CHAIN
──────────────────────────────────────────────────────────────
────────
▾ Layer 1 — Hardware (TEE)                              [✓ VE
RIFIED]
    Type             AMD SEV-SNP         AMD SEV-SNP
✓
    Attestation rpt  0x9c4e…a8f3         0x9c4e…a8f3
✓
```

```
    Signed by        AMD · VCEK          AMD · VCEK
✓
    VCEK fingerprint a1:f2:9c:84…e7:2b   a1:f2:9c:84…e7:2b
✓

▾ Layer 2 — Platform (PodVM)                                [✗
FAILED]
    Image            CoCo PodVM v0.17.0  CoCo PodVM v0.17.0
✓
    Signed by        OPAQUE Systems      OPAQUE Systems
✓
    PCR 3            PUAV/LXMAtofR0BV…   PUAV/LXMAtofR0BV…
✓
    PCR 7            ek2aVR7TmEkmNfcP…   x9F3aGgsmKLkmQiP…
✗   bootloader not as expected
    PCR 11           OMoKpGovvdyA/Sgs…   —
—   chain halted at PCR 7

▸ Layer 3 — Application (Workflow)                       [— NOT
REACHED]
    Attestation halted at Layer 2; application layer not eval
uated.
──────────────────────────────────────────────────────────────
────────

WHAT FAILED                                   [ ▸ What to do
(coming soon) ]
PCR 7 measurement does not match the registered manifest valu
e.
Expected:  ek2aVR7TmEkmNfcP…  (bootloader v3.2.1, signed by O
PAQUE Systems)
Observed:  x9F3aGgsmKLkmQiP…
Most likely cause: PodVM image was rebuilt with a different b
ootloader
without re-registering the manifest.
```

Design notes — Pod detail view

- **Coverage period header** anchors the view to a single coherent moment. Per PRD architectural assumption #6, any attestation view must represent one snapshot — hardware, platform, and workload results all originating from the same check. Mixed timestamps produce invalid proof.
- **Layered Trust Chain is the primary skeleton.** The view is organised around the three attestation layers (Hardware/TEE → Platform/PodVM → Application/Workflow), mirroring the structure used in the Governance Record's Workload Verification block. Each layer is independently expandable.
- **Progressive disclosure within each layer.** Collapsed: layer name, verdict chip, one-line summary. Expanded: per-attribute Registered vs Runtime comparison with match indicator. This is the UI analogue of the CLI's `-v` (per-layer outcome) and `-vv` (per-measurement detail) — the Builder shouldn't need to memorise flags to drill in.
- **Failed layers expand by default** to surface the specific mismatched measurement(s) immediately. Layers downstream of a failure are marked *Not reached* rather than failing in their own right (per PRD architectural assumption #2: one failure at any layer fails the chain).
- **Three export actions, not one.** Per PRD FR-2/5/6, three distinct artifacts are produced — Manifest, Result, Evidence. Each gets its own named action with copy explaining when to use it (see Exportable artifacts below). The single "Export report" action in the in-flight Figma mocks elides this distinction and needs to be split.
- **Reserved space for `--explain` remediation guidance.** Hernan is exploring a CLI `--explain <check-id>` flag that surfaces "here are the reasons this check might fail and what to do about it." Not an Alpha requirement, but Katy flagged it as a high-value direction. The "What to do" subsection in the wireframe is the structural placeholder — content can be added later without restructuring.

Workload graph view

The workflow visualisation (orchestrator → models → agents → tools, with edges labelled Attested TLS / Regular TLS) is useful as an *architectural* and *TLS-topology* view, but the in-flight Figma mocks risk a mental-model error: per-node

attestation pills (`CONFIDENTIAL` / `ATTESTED` on individual agents and models) imply a granularity the system does not support.

Per PRD architectural assumption #4: workflow nodes don't have individual attestation. The whole graph runs as a single package inside a pod, and the pod is what's attested. Updates:

- Wrap the graph in a "this graph runs in pod {name}" container and put the runtime verdict at the pod level — not on individual nodes.
- Drop the per-node `CONFIDENTIAL` / `ATTESTED` pills, or reframe them as *configuration intent* (e.g. "configured to require attested TLS") rather than runtime verdict.
- Keep the `Attested TLS` / `Regular TLS` edge labels — those are per-connection properties and remain correct.

Terminology: Workload vs Workflow

The CLI talks about *workloads* (Kubernetes deployments containing pods). The PRD's primary persona is The Builder, who deploys workloads. The in-flight Figma mocks are inconsistent: the landing-page table uses **Workload Attestation** (correct), but the detail panel is titled "Workflow details" and the Summary tab fields read "Workflow name / Workflow measurement / Workflow hash."

Convention to adopt across the Trust Center: **Workload** is the unit of attestation (the K8s deployment). **Workflow** is the orchestrated graph (the Studio artifact) that runs *inside* a workload. Detail panel: rename to **Workload details** (or **Attestation details**). Fields: **Workload measurement**, **Workload hash**.

Exportable artifacts

Three exportable artifacts are produced per workload, aligned to PRD FR-2/5/6 and the three primary use cases:

- **Manifest** — expected measurements + configured policies for a registered workload. Surfaced *before* execution. The artifact The Builder hands to The Data Owner to authorize data access. Plain-language framing, no runtime evidence yet. **Wireframe TODO** — design pass needed.

- **Result — the Governance Record** — signed expected-vs-observed comparison after execution. The artifact The Watchdog and auditors retain as durable proof. Wireframe below (this is the most-developed of the three because it is the primary test instrument for the Q2 buy trigger hypothesis).
- **Evidence** — raw runtime measurements emitted by the verifier on attestation failure. The artifact The Builder uses to debug. Only produced on failure (per PRD architectural assumption #7: evidence is ephemeral; the signed token is the durable proof artifact). **Wireframe TODO** — design pass needed.

Result — Governance Record

A per-workload human-readable document containing the workload identity, policies enforced, regulatory framework mapping, layered workload verification, blocked executions, and a plain-language "What This Proves" section. Intended to be handed by Builders to Data Owners before authorizing data access, and to Watchdogs as proof after execution. Key finding from Q1 research: only 2/7 participants would self-verify; the rest said they'd pass it to legal or security. **Buyers want a document, not a command to run.**

> **Governance Record** (OPAQUE Governance Record) — label validated in Q2 user testing. Engineering and PRD documentation uses AEP (Attested Evidence Pack); use Governance Record on all user-facing surfaces and design documentation.

```
═══════════════════════════════════════════════════════════════
═══════════════

                  OPAQUE GOVERNANCE RECORD
  Record ID:      GR-2026-04-09-0042
  Coverage:       2026-04-09 09:00 → 14:32 UTC
  Workload:       Finance / KYC Workflow
  Generated by:   OPAQUE Attestation Service v3.0
  Signed by:      OPAQUE Root Key · Key ID: rk-prod-9f4a
═══════════════════════════════════════════════════════════════
═══════════════


  VERDICT
```

```
  ┌──────────────────────────────────────────────────────────────────────────────────────────────────────────┐
  │  ✓  ALL CHECKS PASSED                                                                                    │
  │     Manifest match  ·  Hardware valid  ·  Policies enforced                                              │
  └──────────────────────────────────────────────────────────────────────────────────────────────────────────┘


  ────────────────────────────────────────────────────────────────────────────────────────────────────────────

  WORKLOAD IDENTITY
  Name:        KYC Workflow
  Workspace:   Finance
  Version:     2.4.1
  Run ID:      run-8f3c-2026-04-09
  TEE mode:    Production

  ────────────────────────────────────────────────────────────────────────────────────────────────────────────

  POLICIES ENFORCED
  Policy                        Type                Enforced   Scope
  ────────────────────────────────────────────────────────────────────────────────────────────────────────────
  No network egress             Network             ✓          All pods
  TEE required                  Runtime integrity   ✓          All pods
  Shell/exec denial             Pod access          ✓          All pods
  RBAC session scoping          Access              ✓          All pods
```

```
  All policies listed were active and enforced at runtime for
the
  full duration of this execution. Enforcement is hardware-ba
cked
  where marked — not software policy assertion alone.

  ──────────────────────────────────────────────────────────────
──────────


  REGULATORY FRAMEWORK MAPPING
  Each entry maps a regulatory requirement to the specific co
ntrol
  enforced during this execution and the section of this docu
ment
  where supporting evidence can be found.

  Regulation    Article                                    Docu
ment
  ──────────────────────────────────────────────────────────────
──────────
  SOC 2         Art. 9 — ICT security                      Poli
cies Enforced ·
                                                           Work
load Verification
  DORA          Art. 30 — Third-party ICT oversight        Sign
ature ·
                                                           Bloc
ked Executions
  EU AI Act     Art. 15 — Robustness & cybersecurity       Work
load Verification ·
                                                           Bloc
ked Executions
  GDPR          Art. 25 — Data protection by design        Poli
cies Enforced ·
                                                           Work
load Verification
```

```
  GDPR          Art. 32 — Security of processing         Poli
cies Enforced ·
                                                           Sign
ature

  Independent certifications: SOC 2 Type II · ISO 27001 ·
  ISO 42001 furnished upon request.

  ──────────────────────────────────────────────────────────
──────────


  WORKLOAD VERIFICATION
  Registered measurements compared against runtime measuremen
ts.
  Identical values confirm the workload ran exactly as approv
ed.
  Each podVM is a separate execution environment and appears
as a separate block.

  ─── pod-a8f2  ·  Azure (AMD SEV-SNP)  ·  14:30:02 UTC ─────
──────────────────────────────────────────────


  Layer                    Attribute             Registered
(Manifest)          Runtime                ✓
  ──────────────────────────────────────────────────────────
──────────────────────────────────
  Layer 1 — TEE            Type                  AMD SEV-SNP
AMD SEV-SNP            ✓
  (Hardware)               Verified by           Azure Attest
ation Service      [externally verified]  ✓
                           ↳ OPAQUE does not hold Layer 1 ref
erence values.
                             Verification is performed by Azu
re at runtime.

  Layer 2 — Platform       Image                 CoCo PodVM v
```

```
0.17.0 (Fedora)   CoCo PodVM v0.17.0     ✓
                          Signed by             OPAQUE Syste
ms, Inc.           OPAQUE Systems, Inc.   ✓
                          PCR 3                 PUAV/LXMAtof
R0BV...            PUAV/LXMAtofR0BV...    ✓
                          PCR 7                 ek2aVR7TmEkm
NfcP...            ek2aVR7TmEkmNfcP...    ✓
                          PCR 11                OMoKpGovvdy
A/Sgs...            OMoKpGovvdyA/Sgs...    ✓

  Layer 3 — Application    Name                  KYC Workflow
KYC Workflow           ✓
  (Workflow)              Signed by             OPAQUE Syste
ms, Inc.           OPAQUE Systems, Inc.   ✓
                          Workflow server       0x7f3a...b9c
1                  0x7f3a...b9c1          ✓
                          Workflow definition   0x4e2d...a8f
3                  0x4e2d...a8f3          ✓
  ──────────────────────────────────────────────────────────
──────────────────────────────────


  Manifest registered:  2026-03-15  ·  Admin: trish@opaque.co
  Evidence type:        EAT (Entity Attestation Token) — prod
uced at runtime, not retroactively

  Failure types (none triggered in this run):
    — Infrastructure failure   (hardware attestation unavaila
ble)
    — Measurement mismatch     (runtime ≠ registered manifes
t)
    — Invalid evidence         (EAT signature verification fa
iled)

  ──────────────────────────────────────────────────────────
──────────
```

```
  BLOCKED EXECUTIONS  (this coverage window)
  Policy enforcement log — the following attempts were detect
ed and blocked by active controls.

  Timestamp        Policy              Pod          Event
  ──────────────────────────────────────────────────────────────
──────────────────────────

  14:29:58 UTC     Network policy      pod-a8f2     Outbound
to api.openai.com:443 blocked — not in approved allowlist
  14:29:44 UTC     Network policy      pod-c3d1     Outbound
aTLS to payroll-data-api blocked — attestation evidence not p
resented
  14:27:11 UTC     Runtime integrity   pod-a8f2     Inbound c
onnection from claims-analytics-svc rejected — cert not prese
nt
  13:55:02 UTC     Pod access          pod-a8f2     Pod exec
denied — alice.chen@opaque.co attempted kubectl exec on pod-a
8f2

  4 executions blocked · 0 policy violations undetected
  All blocked events are tamper-evidently recorded in the Aud
it Log.

  ──────────────────────────────────────────────────────────────
──────────

  WHAT THIS PROVES
  This is machine-verifiable proof — recorded at runtime,
  not reconstructed for audit. Each claim maps to a concern
  raised by BFSI risk and compliance teams in pre-purchase re
view.

  ✓  No one could access your data during processing
     This workload ran inside a hardware-sealed Trusted
     Execution Environment. Cloud operators, OPAQUE staff,
     and privileged admins are excluded from enclave memory
```

```
   at the hardware level — not by policy alone.
   → See Signed Evidence

✓  Data did not leave the execution environment
   Network isolation was hardware-enforced throughout
   this execution. No outbound transfer was possible.
   All egress controls were active and logged.
   → See Policies Enforced · Signed Evidence

⚠  Access control policies were enforced within execution
   Data retrieval and all agent tool calls in this
   execution ran within the scoped access boundary shown.
   Policies enforced at runtime are documented here.
   Note: OPAQUE scopes enforcement to this execution;
   source-system RBAC definitions are set by your org.
   → See Policies Enforced · Audit Log

⚠  Training data was processed inside a sealed boundary
   Model inputs were confined to this execution
   environment. Egress was blocked by policy. Memorization
   and regurgitation risk is reduced — not eliminated —
   and subject to output guardrails beyond this boundary.
   → See Policies Enforced

★  This is cryptographic proof, not documentation
   These results were produced at the time of processing.
   They describe what happened — not what was intended.
   The signature is machine-verifiable by any party.
   Designed to satisfy DORA Art. 9 & 30, EU AI Act
   Art. 15, and FFIEC AI supervisory expectations.
   → See Signature · How to verify

──────────────────────────────────────────────────────────────────────────────

SIGNATURE
```

```
  Algorithm:    ECDSA-P256-SHA256
  Signed by:    OPAQUE Root Key · rk-prod-9f4a
  Timestamp:    2026-04-09T14:32:17Z
  Fingerprint:  3a:f9:2c:88:b1:e4:... (truncated)

  To verify this record independently:
  $ opaque verify governance-record GR-2026-04-09-0042 --key
rk-prod-9f4a

═══════════════════════════════════════════════════════════════
═══════════════
  This Governance Record was generated by OPAQUE and cryptogr
aphically signed.
  It constitutes machine-verifiable evidence of the execution
above.
═══════════════════════════════════════════════════════════════
═══════════════
```

Design notes and open questions

Regulatory framework mapping (added in current revision)

A **Regulatory Framework Mapping** section was added between Policies Enforced and Workload Verification in the Governance Record. It maps each active policy to the specific regulatory article it satisfies (SOC 2 Art. 9, DORA Art. 30, EU AI Act Art. 15, GDPR Arts. 25 & 32) and points to the section of the document where enforcement evidence lives. This directly serves the use case validated in Q1 / Q2 research: a document Builders hand to Data Owners, legal, or security — meant to be *read*, not a command to run. Reviewers can see at a glance how the artifact satisfies the controls they are responsible for.

Q2 PMF experiment alignment

The WHAT THIS PROVES section is the variable being tested in the Q2 buy trigger hypothesis. The four concerns map to Q1 research findings and OPAQUE's mitigation state as follows:

Concern	Vector	OPAQUE mitigation	Artifact section
Data in use	V2.2	✓ Fully prevents	Signed Evidence
Access control (RBAC)	V1.1	⚠️ Partially mitigates	Policies Enforced · Audit Log
AI derivatives	V6.4	⚠️ Partially mitigates	Policies Enforced
Proof gap	V8.7	✓ Fully mitigates	The entire artifact; Signature

The two ⚠️ items are intentionally honest. BFSI buy committees will scrutinize overclaims. The ⚠️ + scoped note pattern preserves credibility while still showing meaningful mitigation.

Open questions

★ item positioning. V8.7 (proof vs. documentation) may be the highest-value claim for BFSI buyers — it's what turns a SOC 2 doc into something a regulator accepts. Consider whether it should lead the WHAT THIS PROVES section rather than close it.

Attestation cadence. The wireframe assumes per-run attestation. Confirm with engineering whether attestation is per-run or snapshot before locking the Trust Center hierarchy — it affects what the Workload Attestation list shows and how "last run" timestamps behave.

Buy persona validation. The Governance Record concept has been validated with buy personas and the label confirmed in Q2 user testing. WHAT THIS PROVES framing should continue to be refined based on ongoing interview findings before the surface is designed for production.

CLI ↔ UX status taxonomy reconciliation. The CLI uses EAR-aligned terms (*affirming*, *contraindicated*, *no verdict*, *at-risk*). The UX uses *Verified*, *Failed*, *Pending*, *At risk*. Pick one canonical taxonomy and align both surfaces. (Surfaced in CLI review 2026-04-29.)

Failure-type granularity. PRD FR-4 lists three categories (infrastructure failure / measurement mismatch / invalid evidence — with policy violation as a subset of invalid evidence). Current wireframe uses four (splits *connection rejection* out

from invalid evidence). Confirm with Hernan whether to flatten to three or retain four.

Standalone `--pod` view fate. Matthew flagged in the CLI demo that `--pod <name>` isn't more informative than the list view + `-v`; Hernan may drop it. Equivalent UI question: does the workload detail surface need a "single pod" view distinct from the workload list with expanded pod rows? Current recommendation: yes (the layered drill-down won't fit inline in the table) but worth confirming.

Manifest and Evidence export wireframes. The Result artifact (Governance Record) is fully wireframed because of Q2 testing. Manifest and Evidence export shapes have not been wireframed — both are PRD P0 (FR-2, FR-6) and need a design pass.

Workflow graph view — configuration intent vs runtime status. The graph view today blurs the two. Should the per-node pills (if retained) reflect configuration intent (e.g. "configured to require attested TLS") or runtime status, and what attribute makes the distinction visually clear?